

CloudFront Origin Access Settings – Secure Private S3 Origin with OAC

To Begin with the Lab

Summary of the Lab

In this lab, **Amazon CloudFront** was configured to access a private **Amazon S3** bucket securely using **Origin Access Control (OAC)** instead of public bucket access. The lab explained why exposing an S3 bucket through public read permissions is not a secure practice and showed how CloudFront can be used as the only path to the origin. A private S3 bucket was selected as the origin, a CloudFront distribution was created, and the generated bucket policy was applied to allow CloudFront to retrieve objects. The default root object was then configured so the website could load correctly without manually specifying the file name. Finally, the setup was verified by opening the CloudFront URL successfully while keeping direct S3 access restricted.

Understanding Origin Access Settings in Amazon CloudFront

Origin access settings control how an origin can be reached and who is allowed to access it. These settings apply when **Amazon S3** is used as a CloudFront origin, and they decide whether content is reachable directly from S3 or only through **Amazon CloudFront**. The main goal is to protect the origin while still delivering content through CloudFront. This lab focused on keeping the bucket private and allowing CloudFront to be the only valid entry point.

Public Access

Public access means the origin is reachable without restrictions. In this mode, the S3 bucket must be made public, and users can access objects directly through bucket URLs and object URLs. This is simple to set up, but it is not the best choice when security matters. It is mainly useful for openly shared content such as public images, downloads, or simple demo files.

Example:

An S3 bucket configured with public read permissions lets anyone open the website endpoint or individual object URLs directly. That works for public content, but it also means the origin is exposed outside CloudFront.

Origin Access Control (OAC)

Origin Access Control (OAC) is the modern and recommended way to keep an S3 origin private while still allowing **Amazon CloudFront** to read its content. With OAC, the bucket stays private, and a bucket policy grants access only to the CloudFront distribution. This improves security and avoids direct public access to the origin. It is the best choice for new CloudFront setups because it is simpler to manage and integrates cleanly with CloudFront features.

Legacy Access Identities (OAI)

Legacy Access Identities (OAI) is the older method of restricting access to an S3 origin by using a special CloudFront user identity. It serves the same general purpose as OAC, which is to prevent direct public access to the bucket. This option still exists for older environments that already use it. For new work, OAC is preferred over OAI.

Lab Steps

Step 1 — Prepare a Private S3 Origin

- Sign in to the AWS Management Console.
- Open **Amazon S3**.
- Create a private bucket for the website content.
- Keep **Block Public Access** enabled.

The screenshot shows the 'Create bucket' page in the AWS Management Console. The 'Bucket name' field is filled with 'cloudfreeks-private-demo'. Below this, the 'Object Ownership' section shows 'ACLs disabled (recommended)' selected. The 'Block Public Access settings for this bucket' section has 'Block all public access' checked and highlighted with a red box. The page also includes a 'Choose bucket' button and a 'Format: s3://bucket/prefix' text.

- Leave **Static website hosting** disabled.
- Upload the website files into the bucket.
- Verify that the bucket remains private.

Step 2 — Create the CloudFront Distribution

- Open **Amazon CloudFront**.
- Click **Create distribution**.
- Select the private **Amazon S3** bucket as the origin.

Specify origin

Your origin is where your content (such as a website or app) lives. CloudFront works with AWS-based origins and origins hosted on other cloud providers.

Origin type

☒ **Amazon S3**
Deliver static content like files and images, statically generated websites or single page applications (SPA).

☐ Elastic Load Balancer
Deliver applications hosted behind ELB such as dynamic websites, web services, and APIs.

☐ API Gateway
Deliver API endpoints for REST APIs hosted on API Gateway.

☐ Elemental MediaPackage
Deliver end-to-end live events or video on demand (VOD).

☐ VPC origin
Deliver applications and content hosted within private VPCs, such as EC2 instances and Application Load Balancers.

☐ Other
Refer to any AWS or non-AWS origin through its publicly resolvable URL.

Origin

S3 origin
Choose an AWS origin, or enter your origin's domain name. [Learn more](#)

cloudfront-private-demo.s3.us-east-1.amazonaws.com [Browse S3](#)

Origin path - optional
The directory path within your origin where your content is stored. [Learn more](#)

/path

- Tick **Allow private S3 bucket access to CloudFront** and change cache policy to **CacheDisabled** for lab purpose only.

Settings [Info](#)

CloudFront provides default origin and cache settings based on what origin you selected. [View default settings for S3](#)

Allow private S3 bucket access to CloudFront [Info](#)

☒ **Allow private S3 bucket access to CloudFront - Recommended**
This policy allows CloudFront to access the bucket only when the request is on behalf of the CloudFront distribution that contains the S3 bucket. The policy allows CloudFront to access the bucket only when the request is on behalf of the CloudFront distribution that contains the S3 bucket.

Origin settings
Origin settings control how CloudFront connects to the specified origin.

☒ Use recommended origin settings ☐ Customize origin settings

Cache settings
Cache settings determine when CloudFront serves cached content and when it fetches new content from the origin.

☐ Use recommended cache settings tailored to serving S3 content ☒ Customize cache settings

Viewer protocol policy

☐ HTTP and HTTPS
☒ Redirect HTTP to HTTPS
☐ HTTPS only

Allowed HTTP methods

☒ GET, HEAD
☐ GET, HEAD, OPTIONS
☐ GET, HEAD, OPTIONS, PUT, POST, PATCH, DELETE

Cache policy
Choose an existing cache policy or create a new one.

CacheDisabled
Policy with caching disabled

- **Disable Web Application Firewall.**

Enable security

Web Application Firewall (WAF) [Info](#)

☐ Enable security protections
Keep your application secure from the most common web threats and security vulnerabilities using AWS WAF. Blocked requests are stopped before they reach your web servers.

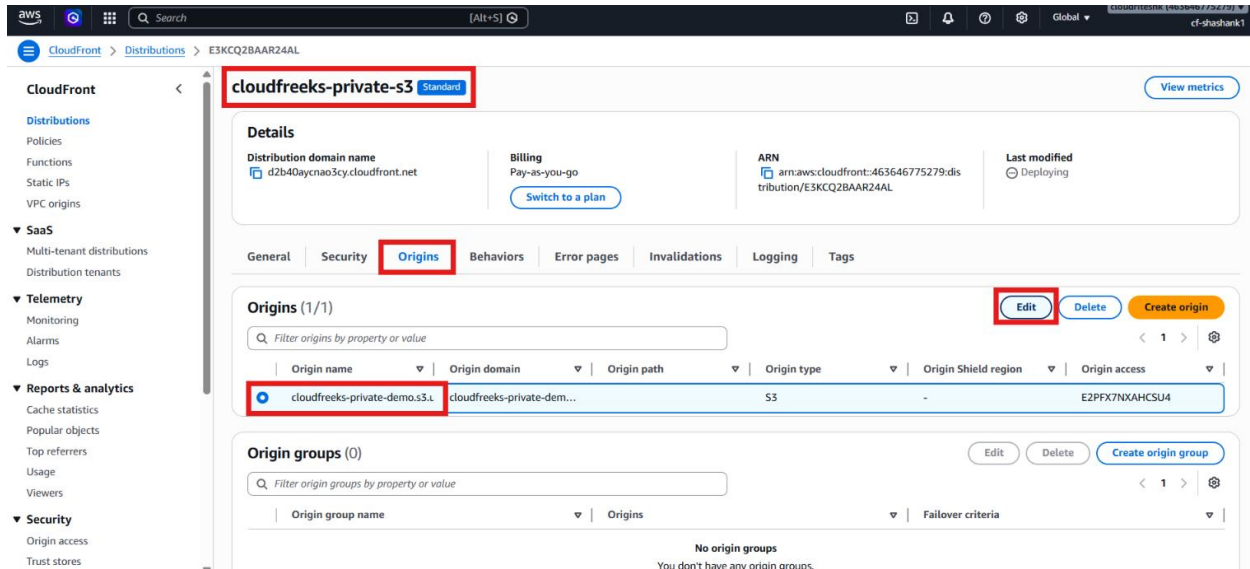
☒ **Do not enable security protections**
If your application does not need security protections from AWS WAF.

[Cancel](#) [Previous](#) [Next](#)

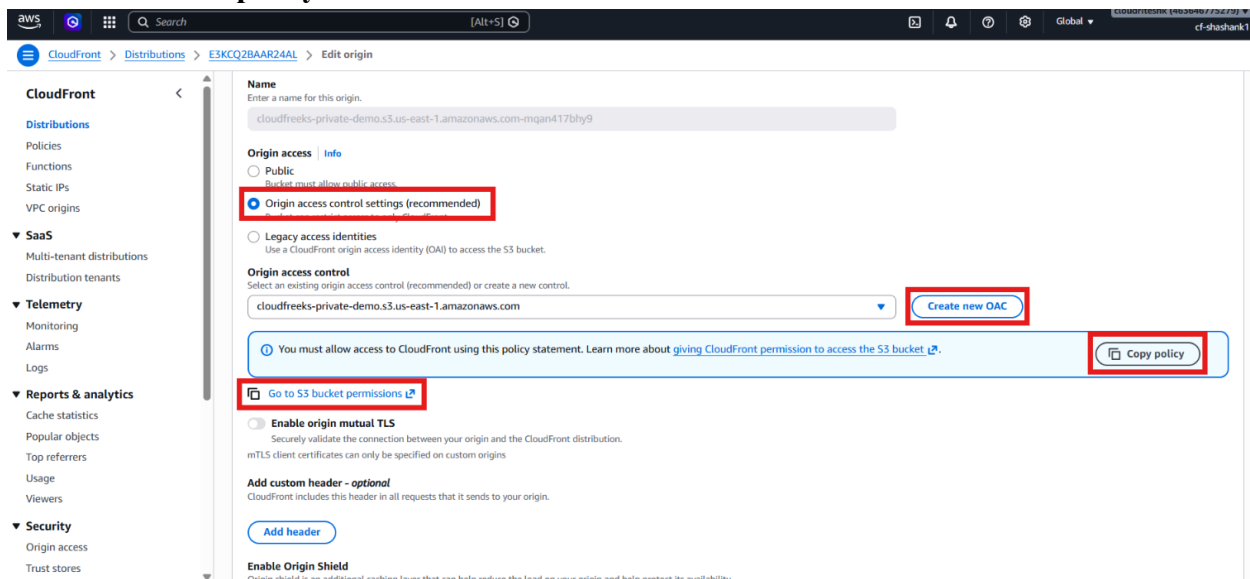
- Create the distribution and wait for deployment.

Step 3 — Update the S3 Bucket Policy

- Open your distribution and **Origin** Select your origin



- Create new OAC.
- Copy the bucket policy generated by **Amazon CloudFront**.
- Open the S3 bucket **Permissions** tab.
- Click **Bucket policy** → **Edit**.



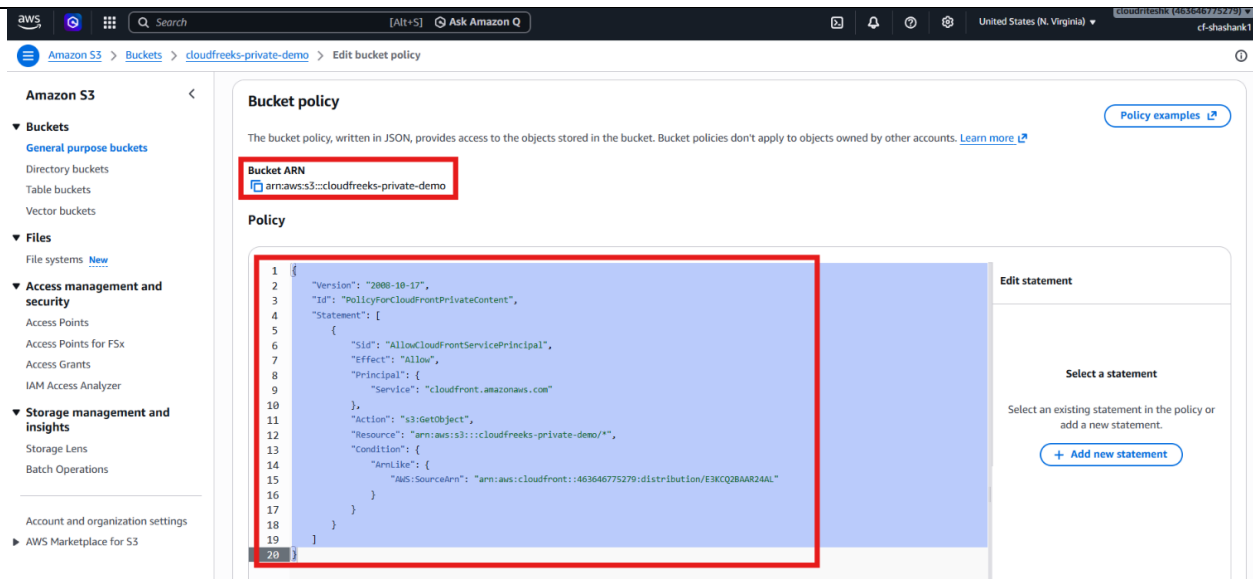
- Paste the generated policy.
- Replace the bucket ARN with your bucket ARN.
- Save the policy changes.

```
{
  "Version": "2008-10-17",
  "Id": "PolicyForCloudFrontPrivateContent",
  "Statement": [
```

```

{
  "Sid": "AllowCloudFrontServicePrincipal",
  "Effect": "Allow",
  "Principal": {
    "Service": "cloudfront.amazonaws.com"
  },
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::cloudfreeks-private-demo/*",
  "Condition": {
    "StringEquals": {
      "AWS:SourceArn":
"arn:aws:cloudfront::463646775279:distribution/E3KCQ2BAAR24AL"
    }
  }
}

```



Step 4 — Configure the Default Root Object

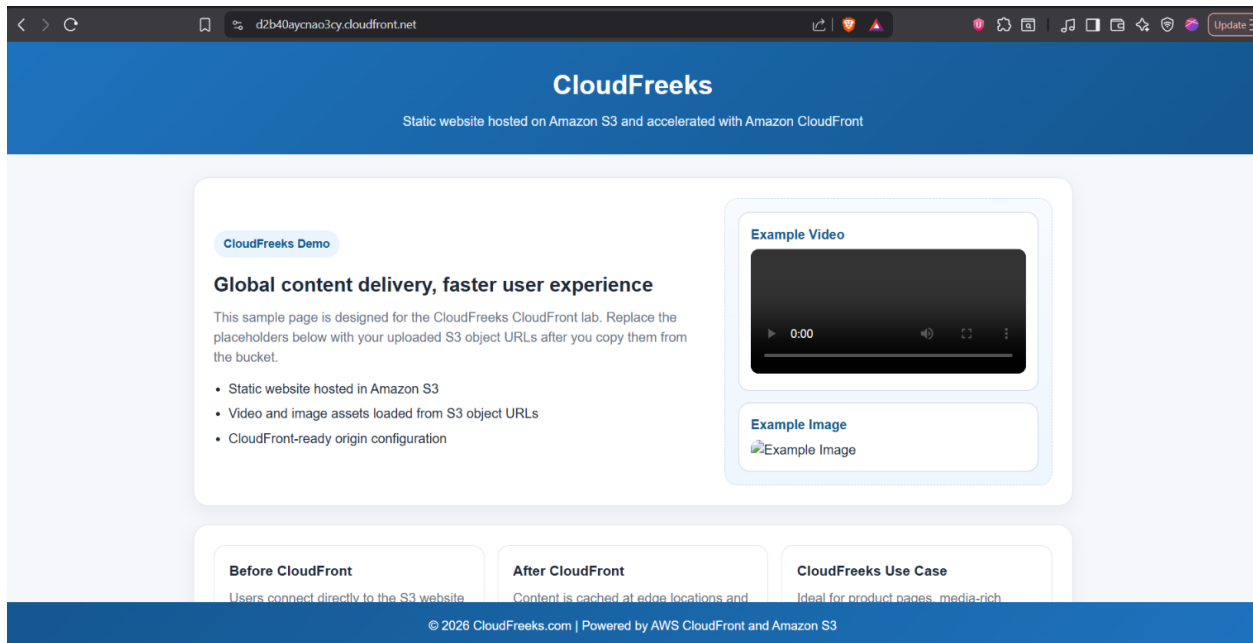
- Open the CloudFront distribution settings.
- Click **Edit**.

The screenshot shows the AWS CloudFront console for a distribution named 'cloudfreeks-private-s3'. The left sidebar contains navigation links for CloudFront, Distributions, Policies, Functions, Static IPs, VPC origins, SaaS, Telemetry, and Reports & analytics. The main content area shows the 'Settings' tab for the distribution. The 'Default root object' is set to 'index.html'. The 'Edit' button is highlighted in the top right corner.

- Set **Default root object** to `index.html`.
- Save the changes.

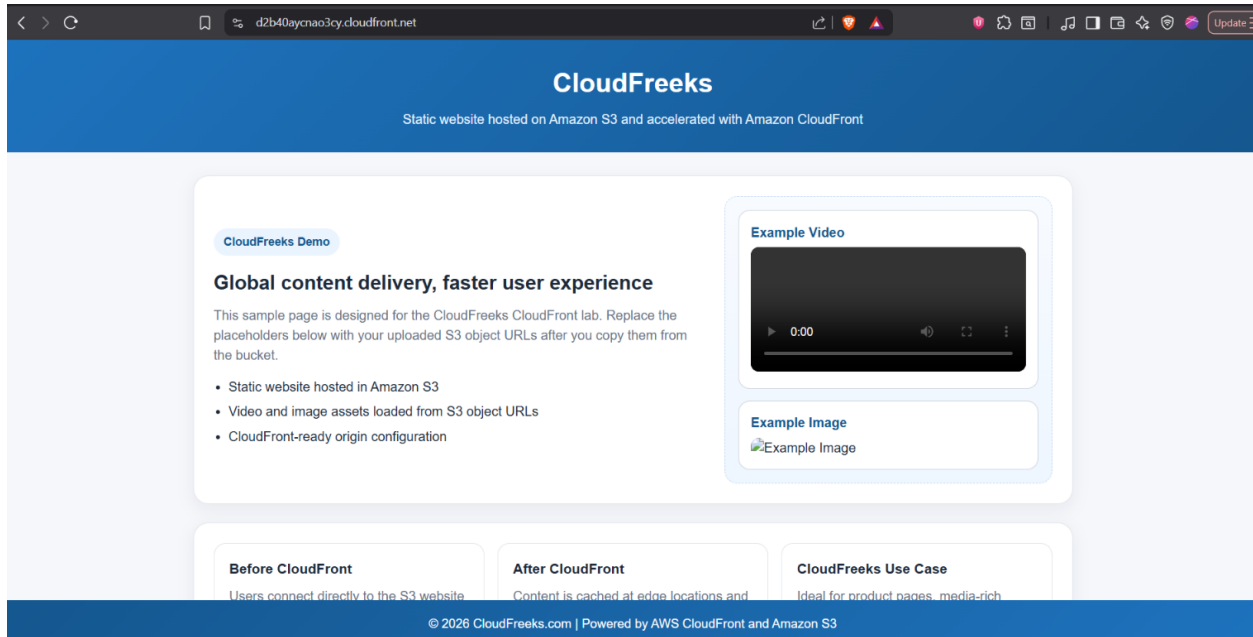
The screenshot shows the 'Edit settings' page for the 'cloudfreeks-private-s3' distribution. The 'General' tab is selected. The 'Default root object' is set to 'index.html'. The 'Edit' button is highlighted in the top right corner.

- Wait for the distribution to finish deploying.
- Verify that CloudFront knows which file to serve as the home page.



Step 5 — Verify Secure Access

- Open the CloudFront distribution URL in a browser.
- Verify that the website loads correctly without exposing the S3 bucket publicly.



- Verify that the website is successfully served through **Amazon CloudFront** only.